

Checklist 15 bước bảo mật thông tin & dữ liệu cục bộ khi dùng AI

Một checklist thực dụng cho người dùng Ollama, LM Studio, local LLM và các script AI trên máy cá nhân hoặc máy nội bộ.

Công nghệ & AI / Bảo mật dữ liệu

Dùng tài nguyên này như thế nào?

Đi qua checklist trước khi đưa dữ liệu thật vào AI. Với dữ liệu nhạy cảm, hãy ưu tiên: phân loại dữ liệu, masking, local/offline, chặn port, xóa log.

Bản thiết kế nội dung: HarryShare.vn
Cập nhật: 08/2026 - Free Resource

1. Phạm vi của checklist

Checklist này dành cho trường hợp bạn xử lý dữ liệu nội bộ bằng AI trên máy cá nhân hoặc máy trong mạng LAN: file khách hàng, ghi chú công việc, dữ liệu đơn hàng, prompt dự án, tài liệu hợp đồng, log nội bộ.

Ma trận rủi ro khi dùng AI với dữ liệu nội bộ

Mức độ phơi bày ra ngoài	Rủi ro vừa: kiểm soát bằng masking	Rủi ro cao: cần local/offline
	Rủi ro thấp: dữ liệu công khai	Rủi ro ẩn: tương ít nhạy cảm nhưng có PII
Mức độ nhạy cảm dữ liệu		

Không có mô hình nào tự làm dữ liệu của bạn an toàn

Local LLM giúp giảm rủi ro gửi dữ liệu ra dịch vụ bên ngoài, nhưng vẫn còn rủi ro từ log, file tạm, extension, quyền thư mục, mạng LAN và chính script bạn chạy.

2. 15 bước kiểm tra bắt buộc

01	[]	Tải Ollama, LM Studio hoặc công cụ local LLM từ trang chính thức; không dùng installer lạ từ forum hoặc link rút gọn.
02	[]	Kiểm tra cấu hình host/bind. Nếu chỉ dùng trên máy cá nhân, ưu tiên bind API vào 127.0.0.1 thay vì 0.0.0.0.
03	[]	Chặn truy cập từ IP ngoài vào port local model, ví dụ 11434 với Ollama, bằng firewall hệ điều hành hoặc router.
04	[]	Tạo thư mục dữ liệu AI riêng, không đặt lẫn Desktop/Downloads nếu có nhiều file nhạy cảm.
05	[]	Phân loại dữ liệu trước khi đưa vào AI: công khai, nội bộ, cá nhân, nhạy cảm, bí mật kinh doanh.
06	[]	Ẩn danh hóa dữ liệu trước khi phân tích: email, số điện thoại, CCCD, địa chỉ, tên khách hàng, mã đơn, token.
07	[]	Tắt internet hoặc chạy trong môi trường cô lập khi xử lý dữ liệu cực kỳ nhạy cảm.
08	[]	Không dán API key, token, cookie, private key, seed phrase, file .env vào prompt.
09	[]	Giới hạn quyền truy cập thư mục cho ứng dụng/script; chỉ cấp đúng folder cần xử lý.
10	[]	Kiểm tra log của ứng dụng AI, terminal, browser extension và script sau khi chạy.
11	[]	Đặt chính sách xóa file tạm, file output nháp và transcript chat sau khi hoàn thành.
12	[]	Không bật tính năng chia sẻ public link, cloud sync hoặc telemetry nếu chưa hiểu dữ liệu nào được gửi đi.
13	[]	Dùng tài khoản hệ điều hành riêng cho máy xử lý dữ liệu khách hàng nếu có thể.
14	[]	Kiểm tra output trước khi gửi lại cho khách: AI có thể vô tình giữ nguyên thông tin nhạy cảm trong bản tóm tắt.
15	[]	Ghi lại quy trình xử lý dữ liệu: ai xử lý, dữ liệu gì, dùng công cụ nào, lưu ở đâu, xóa khi nào.

3. Cấu hình thực tế: ví dụ kiểm tra local port

Windows PowerShell

```
# Kiểm tra tiến trình đang nghe port 11434
netstat -ano | findstr :11434

# Chặn kết nối inbound vào port 11434 từ mạng ngoài
New-NetFirewallRule -DisplayName "Block Ollama Inbound 11434" `
  -Direction Inbound -LocalPort 11434 -Protocol TCP -Action Block

# Chỉ nên mở lại khi thật sự cần dùng qua LAN và đã giới hạn IP nguồn.
```

Linux / Ubuntu

```
# Kiểm tra port
ss -ltnp | grep 11434

# Ví dụ dùng ufw chặn inbound
sudo ufw deny 11434/tcp
sudo ufw status numbered
```

4. Script masking dữ liệu trước khi đưa vào AI

```
import re

PATTERNS = {
    "EMAIL": r"[A-Za-z0-9._%+-]+@[A-Za-z0-9.-]+\.[A-Za-z]{2,}",
    "PHONE": r"(?:\+84|0)?\d{8,10}\d",
    "CCCD": r"\b\d{12}\b",
    "TOKEN": r"(?i)(api[_]?key|token|secret)\s*[:=]\s*['\"]?[^\"'\s]+",
}

def mask_text(text: str) -> str:
    for label, pattern in PATTERNS.items():
        text = re.sub(pattern, f"{{label}}_REDACTED", text)
    return text

raw = open("input.txt", "r", encoding="utf-8").read()
clean = mask_text(raw)
open("input_masked.txt", "w", encoding="utf-8").write(clean)
print("Done: dữ liệu đã được ẩn danh cơ bản.")
```

Giới hạn của masking tự động

Regex chỉ bắt được mẫu rõ ràng. Tên người, địa chỉ viết tự do, nội dung mô tả cá nhân hoặc bí mật kinh doanh vẫn có thể lọt. Với dữ liệu nhạy cảm, cần review thủ công thêm một lượt.

5. Ưu điểm và nhược điểm của local AI

Ưu điểm	Nhược điểm
Dữ liệu không cần gửi lên dịch vụ AI bên ngoài nếu cấu hình đúng.	Vẫn có rủi ro từ log, malware, extension, sync folder, quyền file.
Có thể chạy offline cho tài liệu nhạy cảm.	Chất lượng mô hình nhỏ có thể kém hơn cloud model mạnh.

Ưu điểm	Nhược điểm
Kiểm soát được model, version, dữ liệu input/output.	Tốn RAM/VRAM, dễ treo máy khi xử lý lô lớn.
Phù hợp với quy trình nội bộ cần bảo mật hơn.	Người dùng dễ có cảm giác an toàn giả nếu không cấu hình mạng và log.

6. Quy tắc dùng AI với dữ liệu khách hàng

- Chỉ đưa dữ liệu tối thiểu cần thiết cho mục tiêu xử lý.
- Tách dữ liệu định danh khỏi nội dung cần phân tích nếu có thể.
- Không lưu transcript AI chứa dữ liệu khách hàng lâu hơn nhu cầu công việc.
- Khi dùng dịch vụ cloud AI, đọc lại chính sách dữ liệu và thỏa thuận xử lý dữ liệu trước khi đưa thông tin nhạy cảm.
- Với dữ liệu cá nhân, nên có mục đích xử lý rõ, thông báo/đồng ý phù hợp và biện pháp bảo vệ tương xứng.

7. Bảng ưu tiên triển khai

Mức ưu tiên	Việc cần làm	Vì sao
Ngay hôm nay	Chặn port, không đưa secret vào prompt, masking dữ liệu.	Giảm ngay rủi ro rò rỉ phổ biến nhất.
Trong tuần này	Tạo folder riêng, chính sách xóa log, checklist output.	Tạo thói quen vận hành an toàn.
Trong tháng này	Viết quy trình xử lý dữ liệu, phân loại dữ liệu, backup/restore.	Phù hợp khi làm với khách hàng hoặc team nhỏ.

Ghi chú pháp lý: Khi xử lý dữ liệu cá nhân tại Việt Nam, nên tham khảo Nghị định 13/2023/NĐ-CP về bảo vệ dữ liệu cá nhân và các quy định liên quan. Tài liệu này là checklist thực hành, không phải tư vấn pháp lý.